

Lista de Revisão

Auditoria e Segurança de Sistemas de Informação

Prof. Roberto Cabral

22 de julho de 2025

Aluno: [] Matrícula: []

1. O que é a Lei Geral de Proteção de Dados Pessoais (LGPD), qual sua importância em relação à privacidade e aos direitos humanos, e em que situações específicas ela não é aplicável?
2. Descreva detalhadamente os papéis do Titular de Dados, Controlador de Dados e Operador de Dados sob a LGPD, utilizando exemplos práticos para ilustrar suas interações e responsabilidades.
3. A LGPD elenca dez princípios para o tratamento de dados pessoais. Detalhe esses princípios, explicando como eles devem ser respeitados pelos agentes de tratamento e qual a sua aplicabilidade prática.
4. Descreva três direitos fundamentais dos titulares de dados pessoais garantidos pela LGPD, tais como o direito de acesso, o direito ao consentimento, a retificação, a anonimização, a eliminação ou a portabilidade.
5. Defina os conceitos de ameaça, vulnerabilidade e risco no contexto da segurança da informação, explicando como eles se interligam para impactar os ativos de uma organização.
6. O que é um Sistema de Gestão da Segurança da Informação (SGSI) conforme a ISO 27001? Descreva sua finalidade e os elementos chave que o compõem.
7. Explique a relação fundamental entre a ISO/IEC 27001 e a ISO/IEC 27002. Qual é a principal distinção entre “o quê” e “como” no contexto dessas normas, e qual delas é certificável?
8. Discorra sobre a importância da Cláusula 4 (Contexto da Organização) da ISO 27001 para o estabelecimento de um SGSI. Como a compreensão das questões internas e externas, e das necessidades das partes interessadas, influencia o escopo do SGSI?

9. Como a Cláusula 5 (Liderança) da ISO 27001 enfatiza o comprometimento da Alta Direção com o SGSI? Cite exemplos de ações e evidências que um auditor de SI buscaria para verificar esse compromisso.
10. Descreva o processo de Planejamento de segurança da informação, conforme a Cláusula 6 da ISO 27001. Aborde como as organizações devem realizar a avaliação e o tratamento de riscos, e a importância da Declaração de Aplicabilidade (SoA).
11. Selecione e exemplifique um controle organizacional e um controle de pessoas da ISO 27002, descrevendo como um auditor de SI poderia verificar a eficácia da implementação de cada um deles.
12. Selecione e exemplifique um controle físico e um controle tecnológico da ISO 27002, descrevendo como um auditor de SI poderia verificar a eficácia da implementação de cada um deles.
13. Qual é o papel fundamental do Auditor de Sistemas de Informação (SI) ao utilizar a ISO/IEC 27002? Explique como essa norma serve como um guia essencial para o auditor, desde o planejamento até o relato de achados e recomendações.
14. Discuta a importância da melhoria contínua do SGSI, conforme abordado na Cláusula 10 da ISO 27001. Como a gestão de não conformidades e ações corretivas contribui para o fortalecimento e a evolução do sistema de segurança da informação?
15. Explique o conceito de "Privacy by Design" e descreva três de seus princípios, mostrando como essa abordagem pode ser incorporada no desenvolvimento de sistemas para garantir a segurança e a privacidade dos dados desde a concepção.
16. Selecione e exemplifique o controle organizacional 5.1 (Políticas de segurança da informação) e o controle de pessoas 6.1 (Triagem) da ISO 27002:2022. Descreva como um auditor de SI poderia verificar a eficácia da implementação de cada um desses controles, buscando evidências e realizando testes práticos.
17. Selecione e exemplifique o controle físico 7.7 (Mesa limpa e tela limpa) e o controle tecnológico 8.5 (Gerenciamento de acesso privilegiado) da ISO 27002:2022. Descreva como um auditor de SI poderia verificar a eficácia da implementação de cada um desses controles, buscando evidências e realizando testes práticos.
18. Selecione e exemplifique o controle organizacional 5.7 (Inteligência de ameaças) e o controle tecnológico 8.12 (Prevenção de vazamento de dados) da ISO 27002:2022. Descreva como um auditor de SI poderia verificar a eficácia da implementação de cada um desses controles, buscando evidências e realizando testes práticos.
19. Selecione e exemplifique o controle físico 7.10 (Armazenamento de mídias) e o controle de pessoas 6.8 (Trabalho remoto) da ISO 27002:2022. Descreva como um auditor de SI

poderia verificar a eficácia da implementação de cada um desses controles, buscando evidências e realizando testes práticos.

20. Selecione e exemplifique o controle organizacional 5.23 (Segurança da informação no uso de serviços em nuvem) e o controle tecnológico 8.11 (Mascaramento de dados) da ISO 27002:2022. Descreva como um auditor de SI poderia verificar a eficácia da implementação de cada um desses controles, buscando evidências e realizando testes práticos.
21. Todos os labs do Moodle.